LABORATUVAR 6 · GENEL SÜRÜM · Mori Seiki NH5000 DCG

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Enis UZUN | Grup Gündüz B | Tarih 06/11/2026

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Aranacaklar: OT/siber güvenlik sorumlusu ve BT, üretim ve bakım müdürü, servis firması irtibatı. İlk üç eylem: (1) Önce emniyet: şüpheli konfigürasyonla çalışan makineyi kontrollü durdururum (normal durdurma, kapı kilitli); kapatma veya reset yok. (2) Ele geçirilen servis hesabını ve uzak erişim yolunu devre dışı bırakır, ağ bağlantısını keserim; cihaza dokunmam. (3) Saati, alarmları ve ekranları kayda alır, olay günlüğünü başlatırım (ne, ne zaman, kim gördü).

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Emniyet: safety yolu bağımsızdır; E-stop, kapı interlock ve STO testi geçmeden makine çalıştırılmaz. Kanıt: PLC/CNC konfigürasyonu ve parametreleri yedeklenir, önceki yedekle karşılaştırılır; VPN/jump server oturum kayıtları, firewall ve hesap giriş logları, ekran görüntüleri saklanır. Kapatılan hesap: ele geçirilen servis hesabı ve aynı parolayı kullanan hesaplar; açık oturumlar sonlandırılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Ne oldu (yetkisiz servis hesabı erişimi), ne zaman fark edildi (10:15), etkilenen makine ve yazılım sürümü, kötü niyet şüphesi, emniyet etkisi var mı, alınan ilk önlemler. Eksik bilgiyle de gönderilir; ayrıntı sonra eklenir.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden: OT güvenlik + servis firması (hesap nasıl ele geçti, PLC'de ne değişti). Etki: bakım/emniyet sorumlusu (safety, üretilen parçalar). Önlem: BT/OT ağ ekibi + üretici (hesap, MFA, yama). Bildirimi yönetim/uyum sorumlusu üreticiyle koordineli iletir.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   VPN/jump server oturum kayıtları, hesap ve firewall logları; PLC/CNC değişiklik, alarm ve parametre geçmişi; olay öncesi/sonrası konfigürasyon yedekleri ve hash'leri; ekran görüntüleri, bakım kayıtları, saat senkronu (NTP); olay zaman çizgisi ve alınan önlemler.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.